

Care Access Navigator

Network Security Implementation Plan and Progress Report for Network Security Assignment

The Care Access Navigator capstone is currently in Week 2 (Foundation Infrastructure & IAM Lab), day 1: the project workspace and the Keycloak lab are being set up, and applications, users/groups, and the logging foundation are in progress but not yet complete. This report is written to reflect that status accurately: items that have reached a design decision are marked as such, and every configuration, tool run, and piece of evidence described below is planning/design work to be implemented in the weeks indicated, not something already deployed and tested end to end. Wording throughout uses "will be implemented," "is planned to," and "the intended configuration is" rather than past-tense completion language, and each section states the specific project week the implementation work is scheduled for, based on the 12-week milestone plan in the Project Design Documentation.

Status and timeline alignment

#	Rubric criterion	Aligned project week(s)	Status as of Week 2, Day 1
1	Understand and Implement Network Topologies	Week 2 (Foundation Infrastructure)	Design complete; lab build-out of the addressed VLANs is in progress this week
2	Design Network Protocols and Architectures	Week 2-3 (Foundation / IAM Architecture)	Design complete; addressing plan finalized, protocol choices pending confirmation once Keycloak is fully configured in Week 3
3	Implement Network Security Fundamentals	Week 5-6 (Authentication & Privileged Access / SIEM)	Not started; rule logic drafted below for review, deployment planned for Weeks 5-6
4	Implement Access Control Measures	Week 3 (IAM Architecture & RBAC)	Not started; role model drafted below, to be implemented once Keycloak realm/groups are configured in Week 3
5	Secure Wireless Networks	Week 2-5 (Foundation build-out / Authentication)	Not started; configuration planned below, targeted for completion alongside the authentication work in Week 5
6	Utilize Network Security Tools	Week 6 (SIEM & Security Monitoring)	Not started; tool selection and planned scope defined below
7	Monitor and Respond to Network Security Events	Week 6-7 (SIEM / Incident Detection & Response)	Not started; use case and response runbook drafted below for Week 6-7 execution

1. Understand and Implement Network Topologies

1.1 Objective

Establish the target-state LAN topology for Care Access Navigator so that every later deliverable (IAM, applications, monitoring, GRC reporting) is built onto a network design that is already agreed, rather than improvised zone by zone as the project proceeds.

1.2 Configuration selected: LAN (star topology)

Care Access Navigator will be built as a single simulated site, so a LAN is the applicable configuration. The plan is to implement a star topology: a core switch as the center point, an edge firewall/router facing the internet, and one VLAN per functional zone (DMZ, Management, IAM, Applications, Monitoring, GRC/Reporting) branching from the core switch. The diagram below is the finalized design that the Week 2 lab build-out is working toward.

Care Access Navigator for Simulated Healthcare LAN Topology (Star)

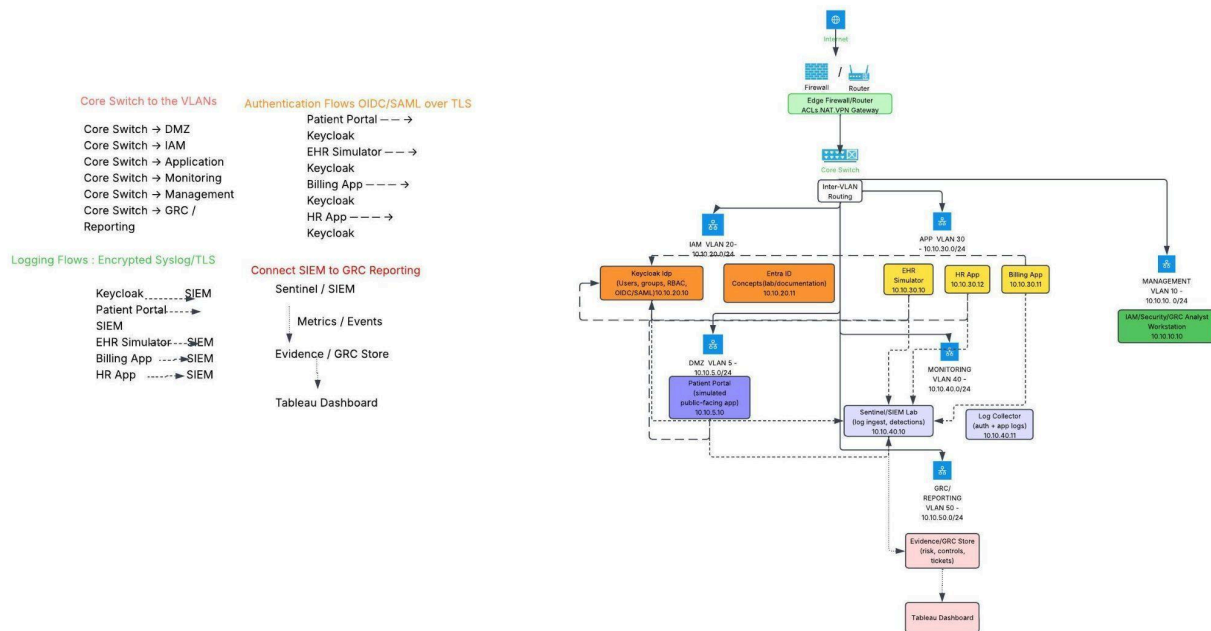


Figure 1. Target-state Care Access Navigator LAN topology (star) — design complete, VLAN build-out in progress.

1.3 Planned build-out tasks (Week 2)

1. Stand up the hypervisor/lab network switch and create the six VLANs shown in Figure 1 with the addressing in Section 2.
2. Deploy the Keycloak VM/container into the IAM VLAN and confirm it is reachable only from the intended VLANs once the edge firewall rules below are applied.
3. Stand up placeholder hosts or containers for the Patient Portal, EHR Simulator, Billing App, and HR App in the DMZ/Application VLANs so later weeks have a live target to configure against.
4. Confirm the logging foundation (planned SIEM lab host in the Monitoring VLAN) can receive a test syslog message from at least one other VLAN before Week 2 closes.
5. Document the as-built VLAN configuration against this design and note any deviations for correction before Week 3 begins.

1.4 How this topology is intended to support secure communication and network management

- Segmentation by function will isolate the DMZ-facing Patient Portal from the IAM, application, monitoring, and GRC zones, so a compromise in one zone will require crossing an inter-VLAN ACL to reach another, once those ACLs are implemented in Section 4.
- All application and IdP traffic is planned to run over HTTPS/TLS or OIDC/SAML over TLS, so authentication and ePHI-adjacent application traffic will be encrypted end to end once TLS certificates are issued in the Week 2-3 lab setup.
- Centralized authentication through the Keycloak IdP is intended to let RBAC and least-privilege decisions be enforced once, rather than duplicated per application — this depends on the RBAC design being finalized in Week 3 (Section 4.2).

- Every zone is planned to forward logs to the monitoring VLAN, with monitoring and GRC both feeding the Tableau dashboard once that integration work happens in Week 11; the topology is being built now specifically so that path exists later without rework.
- A single core switch/firewall will be the one place inter-VLAN rules live, which is intended to keep management, troubleshooting, and change control centralized and auditable as more rules are added in later weeks.

2. Design Network Protocols and Architectures

2.1 Objective

Finalize the addressing plan and the protocol stack for the most connected device in the environment (Keycloak) before dependent applications are configured against it in Week 3, and produce the subnetting and security-protocol design the rest of the project will build on.

2.2 OSI and TCP/IP model for one device: the Keycloak IAM server

The Keycloak IdP is modeled because every application and the DMZ portal will depend on it for authentication once Week 3-4 work is complete. This mapping documents the protocol stack Keycloak is planned to use, so the firewall/ACL rules in Sections 3-4 can be written correctly the first time.

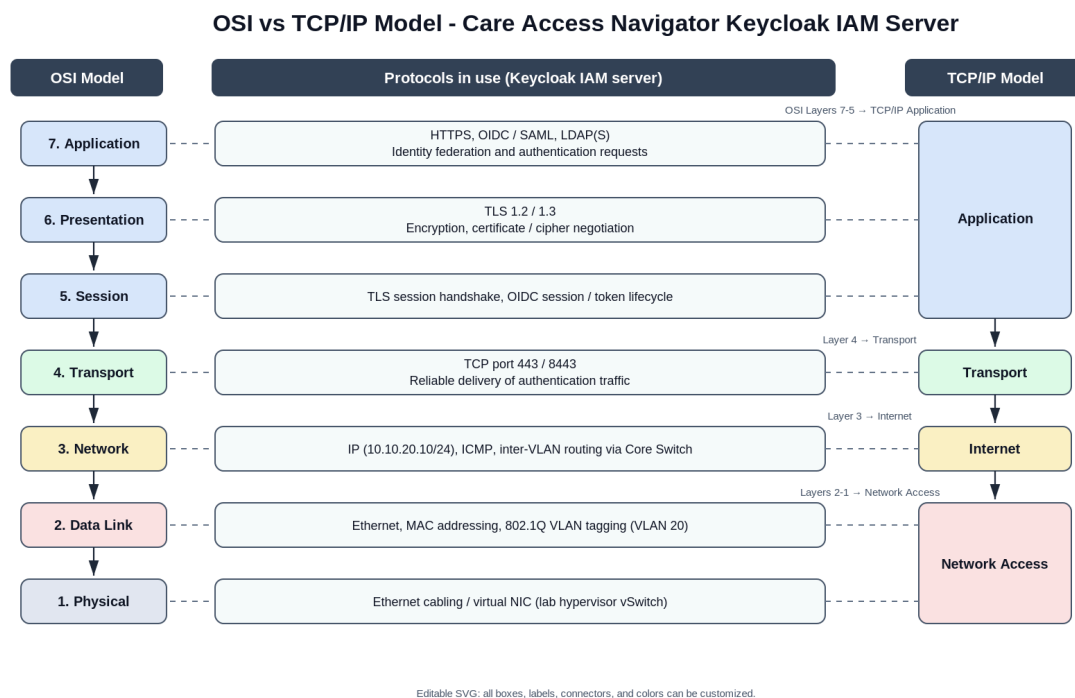


Figure 2. OSI 7-layer and TCP/IP 4-layer models mapped to the protocols the Keycloak IAM server is planned to use.

Layer	Protocol / Control	Planned purpose
Application (L7)	HTTPS, OIDC/SAML, LDAP(S)	Identity federation and authentication requests, to be enabled once realm configuration begins in Week 3

Presentation (L6)	TLS 1.2 / 1.3	Encryption, certificate/cipher negotiation — lab CA and certificates to be issued during Week 2 build-out
Session (L5)	TLS session resumption, OIDC token lifecycle	Session establishment and expiry, to be tuned once initial login testing starts
Transport (L4)	TCP 443/8443	Reliable delivery of auth traffic
Network (L3)	IPv4, inter-VLAN routing, ACLs	Segmentation between zones, per the addressing plan below
Data Link (L2)	Ethernet, 802.1Q, 802.1X	VLAN tagging now, with 802.1X port authentication planned for Week 5

2.3 Proper subnetting for one subnet

The IAM VLAN (parent 10.10.20.0/24) will be subnetted to the size it actually needs before Keycloak is assigned a permanent address in Week 3:

Field	Planned value	Notes
Requirement	Up to 30 usable hosts	Keycloak node, Entra ID concept host, admin jump box, spares
Host bits to borrow	3 bits	$2^5 = 24 + 3$
Planned prefix / mask	/27 = 255.255.255.224	$2^5 - 2 = 30$ usable addresses
Subnet to be used	10.10.20.0/27	Network address 10.10.20.0
Usable range reserved	10.10.20.1 - 10.10.20.30	To be assigned to hosts as they are deployed
Broadcast (reserved)	10.10.20.31	Not to be assigned
Growth block reserved	10.10.20.32/27	Held for IAM-tier growth beyond the current MVP scope

This subnetting decision is being made now, in Week 2, specifically so Keycloak can be deployed directly to its permanent address (10.10.20.10) rather than needing renumbering once Week 3 IAM architecture work begins.

2.4 Secure network architecture with specific security protocols (target state)

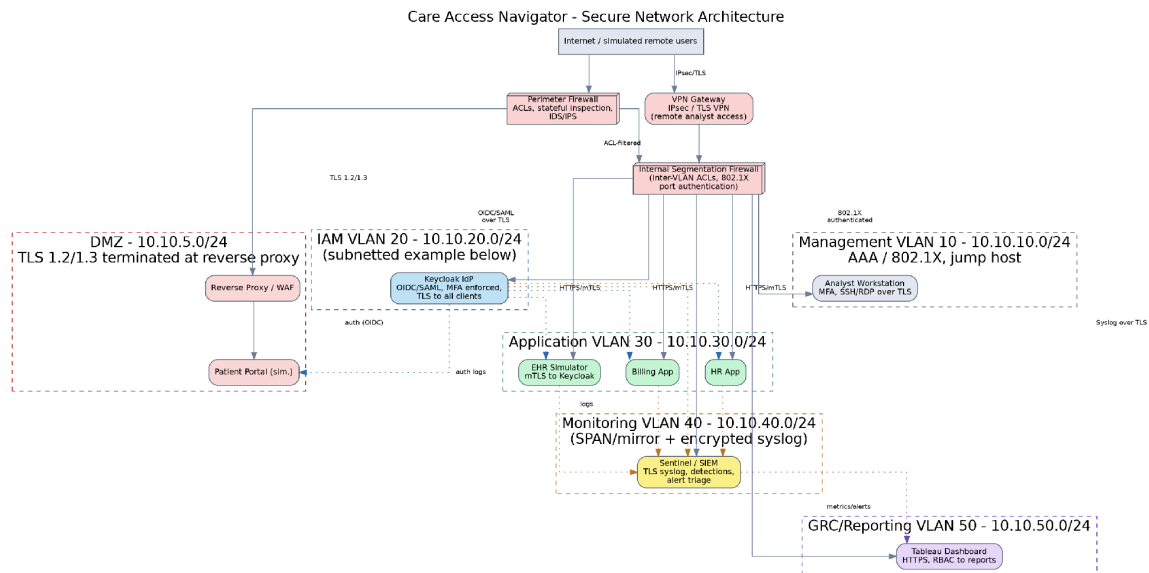


Figure 3. Target-state secure network architecture. Perimeter IDS/IPS, VPN, and internal segmentation controls shown here are design decisions; deployment of each control is scheduled in the weeks noted in Section 3-6 below.

Design intent, by control: perimeter stateful firewall with IDS/IPS (to be deployed alongside the Week 5-6 monitoring work); IPsec/TLS VPN for remote access (planned for Week 5, alongside privileged/remote access controls); TLS 1.2/1.3 termination at the DMZ reverse proxy/WAF (planned once the Patient Portal placeholder is built out further in Week 2-3); 802.1X plus inter-VLAN ACLs at the internal segmentation firewall (planned for Week 3-5); MFA and mTLS at Keycloak (planned for Week 5, per the capstone's Authentication & Privileged Access milestone); and encrypted syslog to the SIEM (planned for Week 6, per the SIEM & Security Monitoring milestone).

3. Implement Network Security Fundamentals

Planned for Weeks 5-6, once Keycloak, the applications, and the SIEM lab are far enough along to generate real authentication and application traffic to write rules against. The configurations below are the drafted rule logic to be reviewed and then deployed at that stage.

3.1 Firewall rule (planned)

To be implemented on the internal segmentation firewall between the Application VLAN (10.10.30.0/24) and the IAM VLAN (10.10.20.0/27). The intended rule allows only the OIDC/SAML callback port from the app tier to Keycloak, with everything else to that host denied by default:

```
# DRAFT - Rule 10 - allow app tier -> Keycloak OIDC/SAML callback over TLS
iptables -A FORWARD -s 10.10.30.0/24 -d 10.10.20.10 -p tcp --dport 8443 -j ACCEPT

# DRAFT - Rule 900 - default deny, all other traffic into the IAM VLAN
iptables -A FORWARD -d 10.10.20.0/27 -j DROP

# DRAFT - Rule 901 - log denied attempts for future SIEM ingestion
iptables -A FORWARD -d 10.10.20.0/27 -j LOG --log-prefix "CAN-IAM-DENY: "
```

Planned validation once deployed: confirm the app tier can reach Keycloak on 8443 only, confirm a test connection to any other port on 10.10.20.10 is dropped and logged, and capture both results as evidence for this criterion.

3.2 IDS configuration (planned)

A Suricata signature (IDS/detect-only mode) is planned to watch for repeated HTTP 401 responses from Keycloak, indicating a possible brute-force login attempt — this will implement the capstone's Week 6 "repeated failed logins" monitoring use case once Keycloak login traffic exists to test against.

```
# DRAFT signature - to be loaded once Suricata is deployed to the Monitoring VLAN
alert http $EXTERNAL_NET any -> $HOME_NET 8443 (msg:"CAN-IDS - Possible Keycloak Brute Force
(5x 401 in 60s)";
  flow:established,to_client; http.stat_code; content:"401";
  threshold:type threshold, track by_src, count 5, seconds 60;
  classtype:attempted-user; sid:1000001; rev:1;)
```

3.3 IPS configuration (planned)

The same detection logic is planned to be enforced inline (IPS/prevent mode) once Suricata is confirmed working in IDS mode, so the source will be actively blocked rather than only alerted on, with a time-boxed drop to avoid permanently blocking a shared/NATed address:

```
# DRAFT - to be enabled after IDS mode is validated
drop tcp $EXTERNAL_NET any -> $HOME_NET 8443 (msg:"CAN-IPS - Block Brute Force Source";
  flow:established; threshold:type threshold, track by_src, count 5, seconds 60;
  classtype:attempted-user; sid:1000002; rev:1;)

# DRAFT companion dynamic block (fail2ban-style), 30 minute cool-down
iptables -I FORWARD -s <offending_src_ip> -j DROP # to be inserted automatically, expiring
after 1800s
```

3.4 Planned example of a detected event

Once the rules above are deployed, the intended test is to generate five failed logins against Keycloak from a single test source and confirm the SIEM produces an alert in this shape, which will then be captured as the evidence artifact for this criterion:

```
{
  "timestamp": "<to be captured at test time>",
  "event_type": "alert",
  "src_ip": "<test source IP>",
  "dest_ip": "10.10.20.10",
  "dest_port": 8443,
  "alert": {
    "signature": "CAN-IPS - Block Brute Force Source",
    "signature_id": 1000002,
    "action": "blocked",
    "category": "Attempted User Privilege Gain"
  },
  "http": { "status": 401, "hostname": "idp.can.local" }
}
```

Planned analyst action once this occurs for real: confirm the IPS auto-block fired, confirm no successful authentication happened in the same window, and record the disposition (contained / escalated) in the case log.

4. Implement Access Control Measures

Access control for the Care Access Navigator environment is planned for **Week 3**, when the Keycloak IAM system, user groups, and roles are configured. The purpose of this phase is to make sure that users, applications, and network segments can access only the resources required for their responsibilities. The design combines firewall-based Access Control Lists (ACLs) with Role-Based Access Control (RBAC) in Keycloak.

4.1 Access Control List (ACL) Configuration

ACLs will be used on the internal segmentation firewall to control communication between the different VLANs. Instead of allowing all traffic between network segments, only specific connections required by the applications and administrators will be permitted.

#	Source	Destination	Port/Protocol	Planned Action	Purpose
10	10.10.30.0/24 (App)	10.10.20.0/27 (IAM)	8443/tcp	Allow	OIDC/SAML callback
20	10.10.5.0/24 (DMZ)	10.10.20.0/27 (IAM)	8443/tcp	Allow	Portal login redirect
30	10.10.20.0/27 (IAM)	10.10.40.0/24 (Mon.)	6514/tcp	Allow	Encrypted syslog to SIEM
40	10.10.10.0/24 (Mgmt)	Any internal VLAN	22,443/tcp	Allow (802.1X required)	Admin access
900	Any	10.10.20.0/27 (IAM)	Any	Deny + log	Default deny to IAM tier

These rules are designed to follow the **least-privilege principle**. For example, the Application VLAN and DMZ will be allowed to communicate with the Keycloak IAM server only on the required authentication port. Keycloak will also be allowed to send encrypted security logs to the Monitoring VLAN for future SIEM analysis.

Administrative access from the Management VLAN will be limited to approved protocols such as SSH and HTTPS. The final ACL rule will deny and log any other unauthorized traffic attempting to reach the IAM VLAN. This default-deny approach helps protect Keycloak because it is a critical system responsible for authentication and authorization across the environment.

Once implemented, the ACLs will be tested to verify that approved traffic is allowed and unauthorized traffic is successfully blocked and logged.

4.2 Role-Based Access Control (RBAC)

Care Access Navigator will use **Role-Based Access Control (RBAC)** through Keycloak. Under this model, permissions will be assigned according to a user's job role rather than individually granting access to every application.

Users will be placed into groups that are mapped to Keycloak roles such as:

- Clinician
- Nurse
- Billing
- HR
- IT Support
- Security Analyst
- Vendor

Applications will use these roles to determine what each user is allowed to access.

RBAC was selected instead of Discretionary Access Control (DAC) or Mandatory Access Control (MAC). DAC would allow individual users or resource owners to make access decisions, which could create inconsistent permissions and make auditing more difficult. MAC provides strict centralized security labels but can be too restrictive for a healthcare environment where employees may frequently change roles or departments.

RBAC is more suitable because it supports **least privilege, easier user management, consistent permissions, and better auditing**. When an employee changes responsibilities, administrators can simply update the user's assigned role rather than modifying permissions separately in each application.

4.3 Standard Clinician Access Level

The first user access level planned for testing is the **Standard Clinician** role, identified in Keycloak as:

can-clinician-standard

A clinician assigned to this role will have read/write access to the EHR Simulator, limited to the patient's records associated with the clinician's assigned workload. The clinician will not have access to the Billing App or HR App because those systems are outside the user's job responsibilities.

Multi-factor authentication is planned to be required for login after the Week 5 authentication work is completed. Sessions will also be configured to expire after **15 minutes of inactivity** to reduce the risk of unauthorized access from unattended devices.

The clinician's access will later be reviewed through the project's periodic access-review process. If the employee changes roles or leaves the organization, access will be modified or removed through the Joiner-Mover-Leaver workflow.

5. Secure Wireless Networks

Wireless security is planned for implementation during **Week 5**, alongside the Authentication and Privileged Access milestone. The goal is to ensure that only authorized users and devices can connect to the clinical wireless network while also protecting wireless communication from common security threats.

The planned wireless network will be named:

CAN-Clinical-WiFi

It will support devices that require access to the Application VLAN.

5.1 WPA3-Enterprise and 802.1X Configuration

The CAN-Clinical-WiFi network is planned to use **WPA3-Enterprise with 802.1X/EAP-TLS authentication**. Instead of using one shared Wi-Fi password, devices will authenticate using certificates and centralized authentication services.

The planned configuration is:

DRAFT hostapd-style configuration

```
ssid=CAN-Clinical-WiFi
wpa=2
wpa_key_mgmt=WPA-EAP
ieee80211w=2
rsn_pairwise=CCMP
auth_server_addr=10.10.20.10
vlan_naming=1
dynamic_vlan=1
```

In this configuration, **WPA-EAP** enables enterprise authentication, while EAP-TLS is intended to provide certificate-based authentication for connecting devices. Management Frame Protection will also be required to provide additional protection against wireless deauthentication attacks.

After a device successfully completes 802.1X authentication, it will be assigned to **Application VLAN 30**. A device without a valid certificate or authentication credential will not receive access to the protected wireless network.

This approach is more secure than using a shared Wi-Fi password because each authorized device can be individually authenticated and access can be removed without changing credentials for all users.

5.2 Wireless Intrusion Prevention System (WIPS)

A **Wireless Intrusion Prevention System (WIPS)** is also planned to provide monitoring for suspicious wireless activity.

The WIPS will focus on detecting two main types of threats.

The first is **rogue access points**. If another wireless access point broadcasts the name **CAN-Clinical-WiFi** but its BSSID is not listed in the authorized access-point inventory, the WIPS will generate an alert. This can help identify unauthorized or potentially malicious wireless devices attempting to imitate the legitimate network.

The second is **deauthentication or disassociation flooding**. The planned rule will generate an alert when more than 10 deauthentication frames are detected for a client within a five-second period. This behavior may indicate an attempt to force a legitimate device off the wireless network.

Both types of WIPS alerts are planned to be forwarded to the **Monitoring VLAN** once SIEM integration is completed during Week 6. This will allow wireless security events to be reviewed together with firewall, authentication, and application security events.

Overall, the planned wireless design combines **WPA3-Enterprise, 802.1X/EAP-TLS, certificate-based authentication, encrypted communication, and WIPS monitoring**. Together, these controls are intended to provide secure wireless access while preventing unauthorized devices from connecting to the clinical network.